

İTÜ

Security in Financial Information Systems

Authentication

Dr. Şerif Bahtiyar
bahtiyars@itu.edu.tr

1

Motivation

623M Payment Cards Stolen from Cybercrime Forum



The Swarmshop cyber-underground “card shop” has been **hit by hackers**, who lifted the site’s database of **stolen payment-card** data and leaked it online.

<https://threatpost.com/623m-payment-cards-stolen-from-cybercrime-forum/165336/>

Dr. Şerif Bahtiyar

Authentication

2

2

Outline

- Basics of Authentication
- Remote User Authentication
- Kerberos

Some slides are based on book of William Stallings, “Cryptography and Network Security: Principles and Practice”, 7th edition, 2017

Dr. Şerif Bahtiyar

Authentication

3

3

Basics of Authentication

Authentication is the **binding** of an **identity** to a **principal**.

- **Message authentication** is a procedure that allows **communicating** parties to **verify** that received or stored **messages** are authentic.
- **User authentication** is the **process of verifying an identity claimed** by or for a system entity. (RFC2828)



Dr. Şerif Bahtiyar

Authentication

4

4

Basics of Authentication

User authentication is the fundamental building block and the **primary line of defense**.



Web authentication is a Layer 3 security feature that causes the controller to not allow IP traffic from a particular client until that client has correctly supplied a valid **username and password**. (Cisco)

Dr. Şerif Bahtiyar

Authentication

5

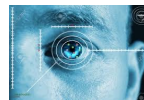
5

Basics of Authentication

User authentication is the **basis** for many types of **access control** and **user accountability**.

Steps of an authentication process:

- **Identification:** **specify** identifier



- **Verification:** **bind** the **entity** and the **identifier**

Dr. Şerif Bahtiyar

Authentication

6

6

Basics of Authentication

Electronic User Authentication is the process of establishing **confidence** in **user identities** that are presented **electronically** to an information system. (NIST SP 800-63-2: Electronic Authentication Guideline)

Digital Authentication or **E-Authentication** may be **used synonymously** when referring to the authentication process that **confirms or certifies a person's identity and works**.

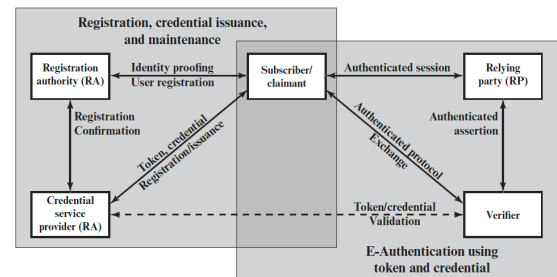
Dr. Şerif Bahtiyar

Authentication

7

7

Basics of Authentication Electronic User Authentication



Dr. Şerif Bahtiyar

Authentication

8

8

Basics of Authentication Electronic User Authentication

- Subscriber** or **Claimant**: The **party to be authenticated**.
- Verifier**: The **party verifying the identity** of a subscriber.



- Credential**: A **data structure** that **authoritatively binds identity** and **additional attributes** to a **token** possessed by a subscriber that can be verified by the verifier in an authentication transaction.
- Token**: can be an encryption key or an encrypted password that **identifies the subscriber**.

Dr. Şerif Bahtiyar

Authentication

9

9

Basics of Authentication Electronic User Authentication

- Registration Authority (RA)**: It is a **trusted entity** that **establishes** and **vouches** for the **identity** of an applicant to a credential service provider.
- Credential Service Provider (CSP)**: CSP **issues** some sort of **electronic credential** to the **subscriber**.
- Relying Party (RP)**: It can **use** the **authenticated information** provided by the **verifier** to make access control or authorization **decisions**.

Note that current network systems may have more complex authentication models, but they contains at least these entities.

Dr. Şerif Bahtiyar

Authentication

10

10

Basics of Authentication

The **initial requirement** of user authentication is **registration**.

Dr. Şerif Bahtiyar

Authentication

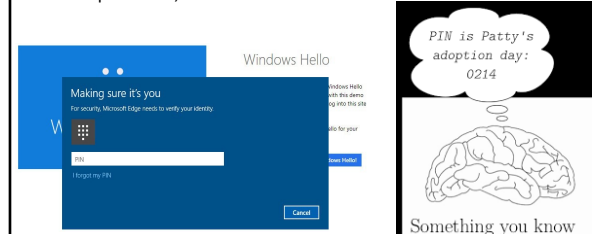
11

11

Basics of Authentication

Four (five) factors of **user authentication** based on individual:

- Knows**: password, PIN



Dr. Şerif Bahtiyar

Authentication

12

12

Basics of Authentication

Four (five) factors of user authentication based on individual:

2-Possesses (token): electronic keycards, smart cards, physical keys



Dr. Şerif Bahtiyar

Authentication

13

13

Basics of Authentication

Four (five) factors of user authentication based on individual:

3-Is (static biometrics):
fingerprint, retina, face



4-Does (dynamic biometrics):
voice pattern, handwriting
characteristic



Dr. Şerif Bahtiyar

Authentication

14

14

Basics of Authentication

Four (five) factors of user authentication based on individual:

5-Location



Each of these methods has problems.

Dr. Şerif Bahtiyar

Authentication

15

15

Mutual Authentication

• Mutual authentication protocols enable communicating parties to satisfy themselves mutually about each other's identity and to exchange session keys.

• Problems of authenticated key exchange

1. Confidentiality

- To prevent masquerade and compromise of session keys, identification and session-key information must be communicated in encrypted form.

2. Timeliness

- A successful replay can disrupt operations by presenting parties with messages that appear genuine but are not.

Dr. Şerif Bahtiyar

Authentication

16

16

Mutual Authentication

Some Replay Attacks

- Opponent simply copies a message and replays it later.
- Opponent replays timestamped message within valid time window.
- Opponent replays timestamped message within valid time window, but in addition, opponent suppresses the original message.
 - The repetition cannot be detected
- A backward replay without modification.
 - Possible if symmetric encryption is used and the sender cannot easily recognize the difference between messages sent and messages received

Dr. Şerif Bahtiyar

Authentication

17

17

Mutual Authentication

Countermeasures against Replay Attacks

- Attach sequence number to each message used in an authentication exchange
 - requires each party to keep track of last sequence number
 - generally not used for authentication and key exchange
- General approaches used
 - Timestamps
 - requires that clocks among various participants be synchronized
 - Challenge/response between A and B
 - requires that response received from B contain the correct nonce value

Dr. Şerif Bahtiyar

Authentication

18

18

Mutual Authentication Timestamps

- It should **not** be used for **connection-oriented** applications because of the **inherent difficulties**:
 - Require **synchronization** among various **processor clocks**
 - Be fault tolerant
 - Cope with network errors
 - Cope with hostile attacks
 - Opportunity for **successful attack** will arise if there is **temporary loss of synchronization** resulting from **fault in the clock mechanism** of one of the parties
 - unpredictable nature of network delays, distributed clocks cannot be expected to maintain precise synchronization



Dr. Şerif Bahtiyar

Authentication

19

19

Mutual Authentication Challenge-Response

Challenge-response approach is **unsuitable** for a **connectionless** type of application

- Requires the **overhead** of a **handshake** before any connectionless transmission



- Effectively **negating** the chief **characteristic** of a **connectionless transaction**.
- For such applications, **reliance** on some sort of secure **time server** and a consistent attempt by each party to keep its clocks in synchronization is a good approach.

Dr. Şerif Bahtiyar

Authentication

20

20

Remote-User Authentication Symmetric Encryption

- This strategy uses **trusted Key Distribution Center (KDC)**
- Each party** in the network **shares a secret key**, known as a **master key**, with the **KDC**.
- KDC generates keys** to be used for a short time over a connection between **two parties**, known as **session keys**, and for distributing those keys **using the master keys** to protect the **distribution**.
- A common approach.

Dr. Şerif Bahtiyar

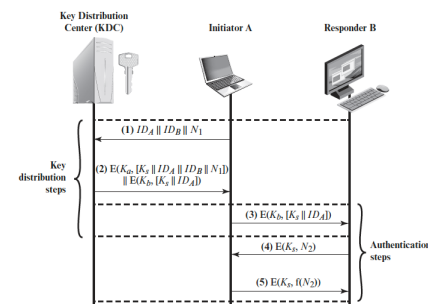
Authentication

21

21

Remote-User Authentication Symmetric Encryption

Needham and Schroeder Protocol



Dr. Şerif Bahtiyar

Authentication

22

22

Remote-User Authentication Symmetric Encryption

Needham and Schroeder Protocol

- Secret keys K_a and K_b are shared between **A** and **KDC** and **B** and **KDC**.
- The **purpose** of the protocol is to **distribute securely** a session key K_s to **A** and **B**. Entity **A** **securely** acquires a **new session key** in step 2.

1. $A \rightarrow KDC: ID_A \parallel ID_B \parallel N_1$
2. $KDC \rightarrow A: E(K_a, [K_s \parallel ID_B \parallel N_1 \parallel E(K_b, [K_s \parallel ID_A])])$
3. $A \rightarrow B: E(K_b, [K_s \parallel ID_A])$
4. $B \rightarrow A: E(K_a, N_2)$
5. $A \rightarrow B: E(K_s, f(N_2))$ where $f()$ is a generic function that modifies the value of the nonce.

- If **opponent captures** the **message** in step 3 and **replay** it, this may **disrupt** operations at **B**.
- Despite handshake of steps 4 and 5, the **protocol** is still **vulnerable** to a form of **replay attack**.

Dr. Şerif Bahtiyar

Authentication

23

23

Remote-User Authentication Symmetric Encryption

T is a **timestamp** that assures **A** and **B** that **session key** has only **just been generated**. Thus, both **A** and **B** know that **key distribution** is a **fresh exchange**.

1. $A \rightarrow KDC: ID_A \parallel ID_B$
2. $KDC \rightarrow A: E(K_a, [K_s \parallel ID_B \parallel T \parallel E(K_b, [K_s \parallel ID_A \parallel T])])$
3. $A \rightarrow B: E(K_b, [K_s \parallel ID_A \parallel T])$
4. $B \rightarrow A: E(K_s, N_1)$
5. $A \rightarrow B: E(K_s, f(N_1))$

$$|\text{Clock} - T| < \Delta t_1 + \Delta t_2$$

Problem: requires clocks to be **synchronized** throughout the **network**. **Distributed clocks** can become **unsynchronized** as a result of sabotage on or faults in the clocks or the synchronization mechanism. $\rightarrow$ **suppress-replay attacks possible**

Dr. Şerif Bahtiyar

Authentication

24

24

Remote-User Authentication

Symmetric Encryption

Counter suppress-replay attacks

- Enforce the requirement that parties regularly check their clocks against KDC's clock.
- Handshaking protocols using nonces -> avoids need for clock synchronization

- $A \rightarrow B: ID_A \parallel N_a$
- $B \rightarrow KDC: ID_B \parallel N_b \parallel E(K_b, [ID_A \parallel N_a \parallel T_b])$
- $KDC \rightarrow A: E(K_a, [ID_B \parallel N_b \parallel K_s \parallel T_b]) \parallel E(K_b, [ID_A \parallel K_s \parallel T_b]) \parallel N_b$
- $A \rightarrow B: E(K_b, [ID_A \parallel K_s \parallel T_b]) \parallel E(K_s, N_b)$

Dr. Şerif Bahtiyar

Authentication

25

25

Kerberos

- Authentication service developed as part of Project Athena at MIT for networks.
- Problem: In distributed environment, a workstation cannot be trusted to identify its users correctly to network services
- Clients and servers trust Kerberos to mediate their mutual authentication
- In unprotected network environment,
 - Risk is impersonation
 - Solution: each server must confirm its identity to clients -> but this is burden -> need a centralized authentication server

Dr. Şerif Bahtiyar

Authentication

26

26

Kerberos

Main threats :

- User may gain access to a particular workstation and pretend to be another user operating from that workstation.
- User may alter the network address of a workstation -> requests sent from altered workstation appear to come from impersonated workstation.
- User may eavesdrop on exchanges and use a replay attack to gain entrance to a server or to disrupt operations.



Dr. Şerif Bahtiyar

Authentication

27

27

Kerberos

- Provides a centralized authentication server whose function is to authenticate
 - users to servers
 - servers to users
- Relies exclusively on symmetric encryption, making no use of public-key encryption
- There are two versions, v4 and v5

Dr. Şerif Bahtiyar

Authentication

28

28

Kerberos

Requirements:

- Secure
 - strong enough that opponent does not find it to be weak link
- Reliable
- Transparent
 - user should not be aware that authentication is taking place
- Scalable
 - support large numbers of clients and servers



Dr. Şerif Bahtiyar

Authentication

29

29

Kerberos

- Kerberos is a trusted third-party authentication service based on Needham and Schroeder protocol.
- It is trusted in the sense that clients and servers trust Kerberos to mediate their mutual authentication
- Build the protocol step by step
 - In an unprotected network environment, any client can apply to any server for service
 - Risk is impersonation -> Opponent can pretend to be another client and obtain unauthorized privileges on server machines

Dr. Şerif Bahtiyar

Authentication

30

30

Kerberos

- Use an **authentication server (AS)** that knows **passwords of all users** and stores these in a **centralized database**.
- AS shares** a unique **secret key** with each **server**. These keys have been **distributed physically** or in some **other secure manner**.

C = client
 AS = authentication server
 V = server
 ID_C = identifier of user on C
 ID_V = identifier of V
 P_C = password of user on C
 AD_C = network address of C
 K_v = secret encryption key shared by AS and V

(1) $C \rightarrow AS$: $ID_C \| P_C \| ID_V$
(2) $AS \rightarrow C$: $Ticket$
(3) $C \rightarrow V$: $ID_C \| Ticket$
 $Ticket = E(K_v, [ID_C \| AD_C \| ID_V])$

Dr. Şerif Bahtiyar

Authentication

31

31

Kerberos

2. Two problems remain

- Minimize number of times that user **enters** passwords
- Plaintext transmission of **password**

Solution: avoiding plaintext passwords and a **new server**, known as the **ticket-granting server (TGS)**

Dr. Şerif Bahtiyar

Authentication

32

32

Kerberos

Once per user logon session:

- (1)** $C \rightarrow AS$: $ID_C \| ID_{TGS}$
(2) $AS \rightarrow C$: $E(K_C, Ticket_{TGS})$

Once per type of service:

- (3)** $C \rightarrow TGS$: $ID_C \| ID_V \| Ticket_{TGS}$
(4) $TGS \rightarrow C$: $Ticket_v$

Once per service session:

- (5)** $C \rightarrow V$: $ID_C \| Ticket_v$
 $Ticket_{TGS} = E(K_{TGS}, [ID_C \| AD_C \| ID_{TGS} \| TS_1 \| Lifetime_1])$
 $Ticket_v = E(K_v, [ID_C \| AD_C \| ID_V \| TS_2 \| Lifetime_2])$

TGS issues tickets to users who have been **authenticated to AS**. Thus, the user **first requests a ticket-granting ticket** ($Ticket_{TGS}$) from the **AS**.

Dr. Şerif Bahtiyar

Authentication

33

33

Kerberos

Table 15.1 Summary of Kerberos Version 4 Message Exchanges

- (1)** $C \rightarrow AS$: $ID_C \| ID_{TGS} \| TS_1$
(2) $AS \rightarrow C$: $E(K_C, [K_{C,TGS} \| ID_{TGS} \| TS_1 \| Lifetime_1] \| Ticket_{TGS})$
 $Ticket_{TGS} = E(K_{TGS}, [K_{C,TGS} \| ID_C \| AD_C \| ID_{TGS} \| TS_1 \| Lifetime_1])$

(a) Authentication Service Exchange to obtain ticket-granting ticket

- (3)** $C \rightarrow TGS$: $ID_C \| Ticket_{TGS} \| Authenticator_C$
(4) $TGS \rightarrow C$: $E(K_{C,TGS}, [K_{C,V} \| ID_V \| TS_2 \| Ticket_v])$
 $Ticket_v = E(K_v, [K_{C,V} \| ID_C \| AD_C \| ID_V \| TS_2 \| Lifetime_2])$
 $Ticket_v = E(K_v, [K_{C,V} \| ID_C \| AD_C \| ID_V \| TS_2 \| Lifetime_2])$
 $Authenticator_C = E(K_{C,TGS}, [ID_C \| AD_C \| TS_1])$

(b) Ticket-Granting Service Exchange to obtain service-granting ticket

- (5)** $C \rightarrow V$: $Ticket_v \| Authenticator_v$
(6) $V \rightarrow C$: $E(K_{C,V}, [TS_3 + 1])$ (for mutual authentication)
 $Ticket_v = E(K_v, [K_{C,V} \| ID_C \| AD_C \| ID_V \| TS_2 \| Lifetime_2])$
 $Authenticator_v = E(K_{C,V}, [ID_C \| AD_C \| TS_3])$

(c) Client/Server Authentication Exchange to obtain service

Dr. Şerif Bahtiyar

Authentication

34

34

Kerberos

- Ticket**
 - contains User ID, server ID, a timestamp, a lifetime, and a copy of session key
 - reusable
 - does not prove anyone's identity but is used to **distribute keys** securely
- Authenticator**
 - proves client's identity
 - used only **once**
 - has **short** lifetime

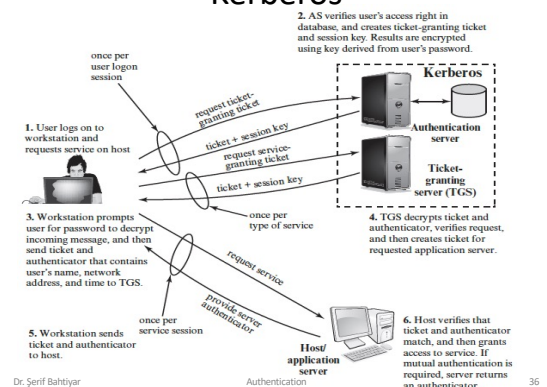
Dr. Şerif Bahtiyar

Authentication

35

35

Kerberos

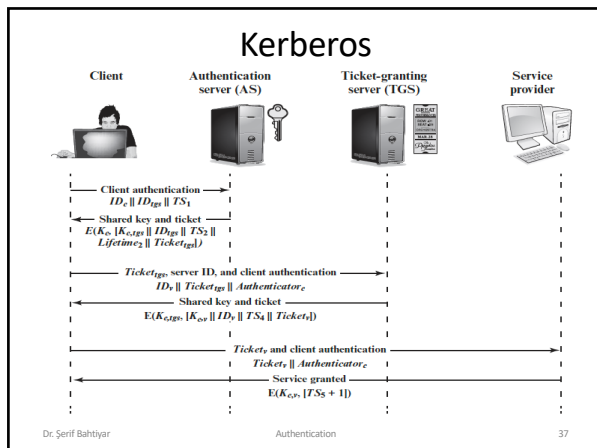


Dr. Şerif Bahtiyar

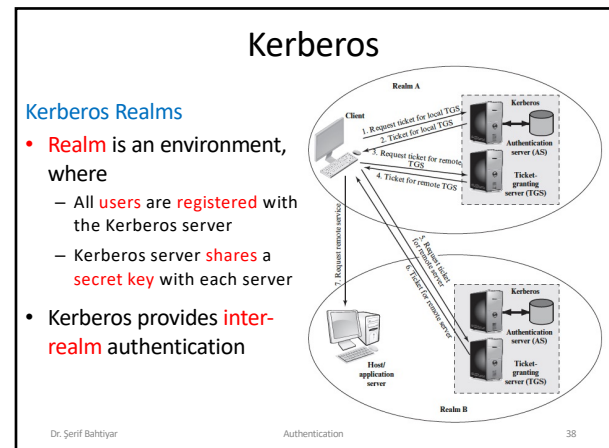
Authentication

36

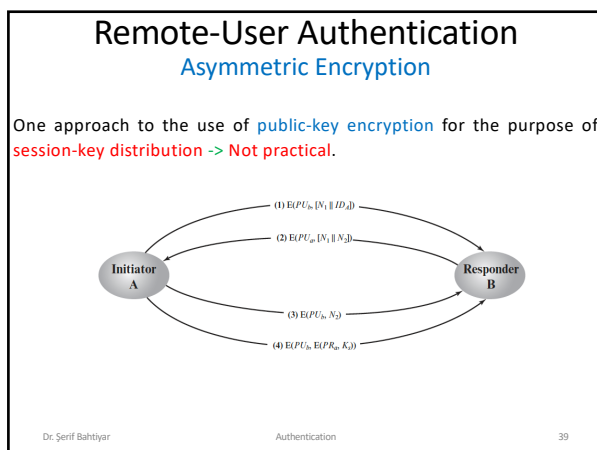
36



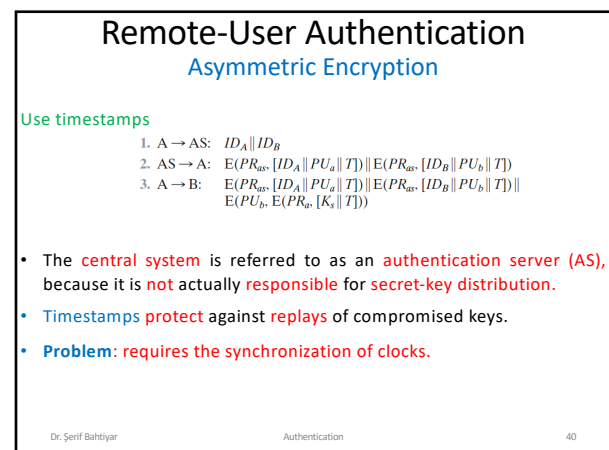
37



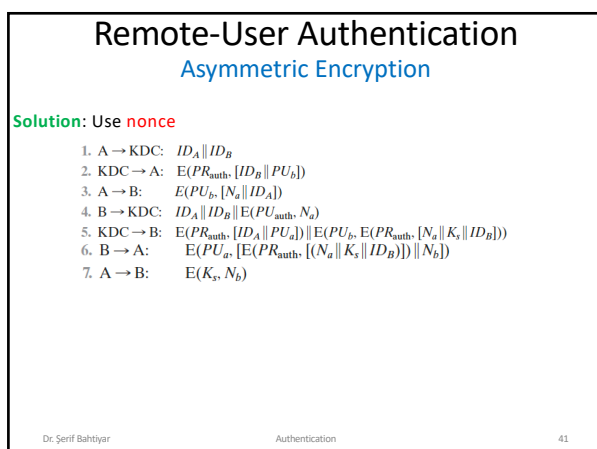
38



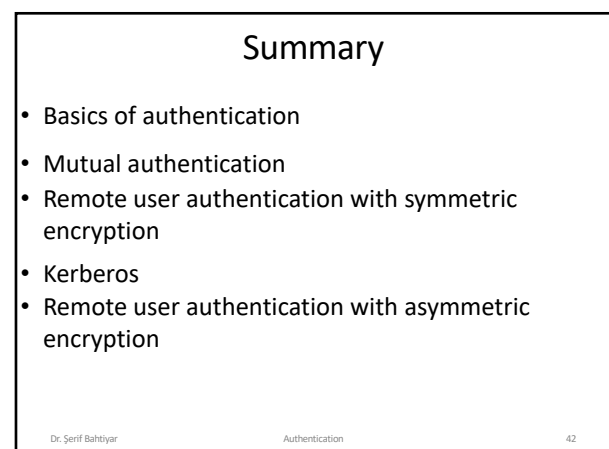
39



40



41



42

Questions?

Dr. Şerif Bahtıyar

Authentication

43

43